CONFIDENTIAL

GRC ASSESSMENT REPORT

ICU IT Environment — NIST Cybersecurity Framework Assessment

Northview Regional Medical Center

FRAMEWORK	PERIOD	PREPARED BY
NIST CSF v1.1	Q1 2025	GRC Analyst — Audit Team

OVERALL RISK POSTURE

HIGH RISK

ORGANIZATION OVERVIEW

Northview Regional Medical Center — ICU IT Environment

200

Bed Regional Hospital

ICU

Connected Medical Devices

EHR

Hybrid On-Prem + Cloud

PHI

PII + Payment Data in Scope

ENVIRONMENT

- Hybrid infrastructure (on-premises + Azure cloud)
- EHR system — primary PHI repository
- ICU biomedical devices (ventilators, monitors, pumps)
- Third-party lab & billing vendor integrations

REGULATORY CONTEXT

- HIPAA Covered Entity — full Security Rule obligations
- PHI, PII, and payment data in scope
- Business Associates: lab and billing vendors
- Third-party vendor PHI exposure currently unassessed

ASSESSMENT SCOPE

Q1 2025 | NIST CSF v1.1 | ICU IT Environment

IN SCOPE

EHR Platform
Hybrid on-prem + Azure cloud

ICU Biomedical Devices
Ventilators, monitors, infusion pumps

Active Directory / IAM
Authentication infrastructure (on-prem)

Network Infrastructure
Switching, routing, firewalls, Wi-Fi

ICU Clinical Workstations
Staff EHR access endpoints

Lab & Billing Systems
Third-party vendor integrations

OUT OF SCOPE

- Non-ICU departments (ED, Surgical, etc.)
- Penetration testing / vulnerability scanning
- Direct assessment of vendor infrastructure
- Financial systems audit (beyond billing vendor)
- Clinical device safety / efficacy review
- Historical audit periods prior to Q1 2025

METHODOLOGY — NIST CSF

National Institute of Standards and Technology Cybersecurity Framework v1.1

IDENTIFY

Asset Mgmt
Risk Assessment
Supply Chain

MATURITY

Level 1 — Ad Hoc

CRITICAL GAPS

PROTECT

Access Control
Data Security
Training

MATURITY

Level 2 — Developing

PARTIAL CONTROLS

DETECT

Monitoring
Anomaly Detection
SIEM

MATURITY

Level 1 — Ad Hoc

CRITICAL GAPS

RESPOND

Response Planning
Communications
Analysis

MATURITY

Level 1 — Ad Hoc

CRITICAL GAPS

RECOVER

Recovery Planning
RTO/RPO
BCP

MATURITY

Level 1 — Ad Hoc

CRITICAL GAPS

Assessment evaluated all 5 NIST functions across ICU systems, EHR, network, devices, and vendor relationships.

TOP 5 CRITICAL RISKS

Ranked by Patient Safety Impact, HIPAA Exposure, and Likelihood of Exploitation

#01 RR-11

No Network Segmentation — ICU Devices Exposed

Ransomware can reach ventilators & cardiac monitors directly from any compromised workstation.

#02 RR-04

MFA Not Enforced on EHR System

Credential theft via phishing gives immediate unrestricted access to all patient PHI.

#03 RR-08

No SIEM or Real-Time Threat Detection

Zero visibility into active breaches. Average healthcare dwell time without detection: 200+ days.

#04 RR-07

PHI Backup Volumes Unencrypted at Rest

Any backup loss is a reportable HIPAA breach. No safe harbour. Immediate compliance liability.

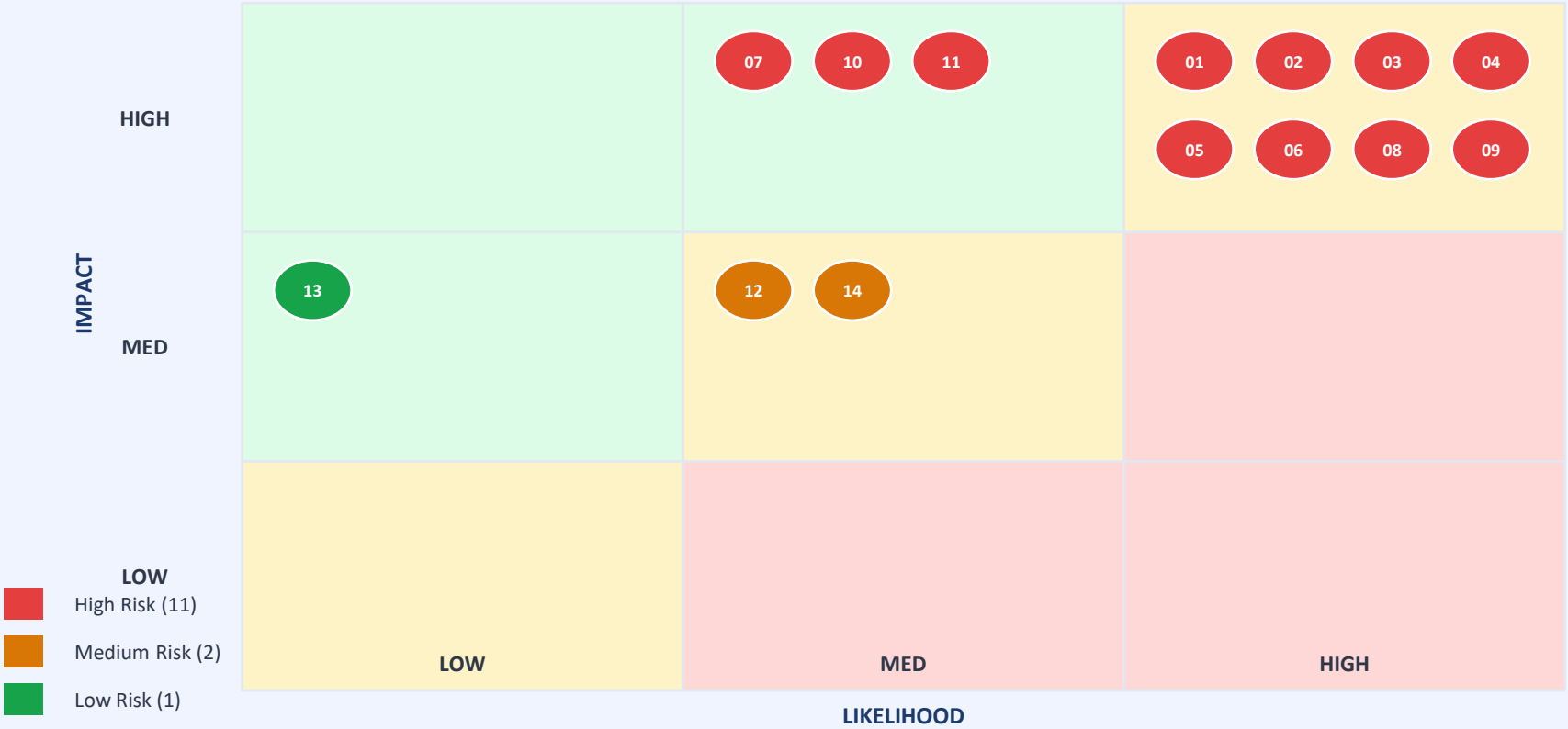
#05 RR-09

Incident Response Plan Outdated & Untested

No ransomware playbook. Cannot meet 60-day HIPAA breach notification requirement.

RISK HEAT MAP

Likelihood vs. Impact Matrix — 14 Identified Risks



MAJOR CONTROL GAPS

0 of 14 Controls Rated Effective | 50% of Controls Weak or Non-Existent

0	6	4	4
EFFECTIVE of 14	PARTIAL of 14	WEAK of 14	NON-EXIST of 14

DOMAIN	CONTROL	EFFECTIVENESS	RISK REF.
TECHNICAL	SIEM & Log Management	Non-Existent	RR-08
TECHNICAL	Network Segmentation (ICU)	Non-Existent	RR-11
ADMIN	Vendor Risk Management	Non-Existent	RR-03
ADMIN	Risk Management Program	Non-Existent	RR-02
TECHNICAL	MFA — EHR System	Weak	RR-04
TECHNICAL	Cloud Security Config.	Weak	RR-14
ADMIN	Information Security Policy	Weak	RR-02
ADMIN	Access Control & RBAC	Weak	RR-05

COMPLIANCE EXPOSURE

HIPAA Security Rule | 7 of 10 Standards Rated Non-Compliant

1	2	7
COMPLIANT	PARTIALLY COMPLIANT	NON-COMPLIANT

HIPAA STANDARD	REQUIREMENT	STATUS	FINDING
§164.308(a)(1)	Risk Management	Non-Compliant	No risk register or program
§164.308(a)(3)	Workforce Access	Non-Compliant	Orphaned accounts active
§164.308(a)(6)	Incident Response	Non-Compliant	IRP outdated and untested
§164.308(a)(7)	Contingency Planning	Non-Compliant	No RTO/RPO defined
§164.312(a)(1)	Access Control / MFA	Non-Compliant	No MFA enforcement for EHR
§164.312(a)(2)(iv)	Encryption at Rest	Non-Compliant	PHI backups unencrypted
§164.312(b)	Audit Controls / SIEM	Non-Compliant	No SIEM, logs unmonitored
§164.312(e)(1)	Transmission Security	Compliant	TLS 1.2/1.3 enforced in transit

HIPAA Penalty Exposure: Up to $1.9M per violation category — multi-category exposure identified in this assessment.

BUSINESS IMPACT

If Current Conditions Lead to a Ransomware Event — What Fails?

Patient Safety

Ransomware propagates to ventilators, infusion pumps, and cardiac monitors via flat network. Clinical devices become unavailable or compromised.

Data Breach

Unencrypted PHI backups exposed. No SIEM to detect exfiltration. Attacker may have undetected access for 200+ days before discovery.

Regulatory

HIPAA breach notification mandatory within 60 days. Outdated IRP means response is uncoordinated. OCR investigation and penalty near-certain.

Financial

Healthcare ransomware recovery avg. $1.3M. HIPAA fines up to $1.9M/category. Cyber insurance may be denied without documented controls.

REMEDIATION ROADMAP

17 Action Items | 3 Phases | Risk-Prioritized Plan

PHASE 1

0 – 30 Days

1. Enforce MFA on EHR — all users
2. Emergency access rights review
3. Revise & reapprove IRP
4. Implement ICU network segmentation
5. Encrypt all PHI backup volumes
6. Establish formal risk register

PHASE 2

1 – 3 Months

1. Deploy SIEM & log management
2. Launch vendor risk program
3. Medical device patching program
4. Define RTO/RPO + backup test
5. Ransomware tabletop exercise
6. Apply cloud security baseline

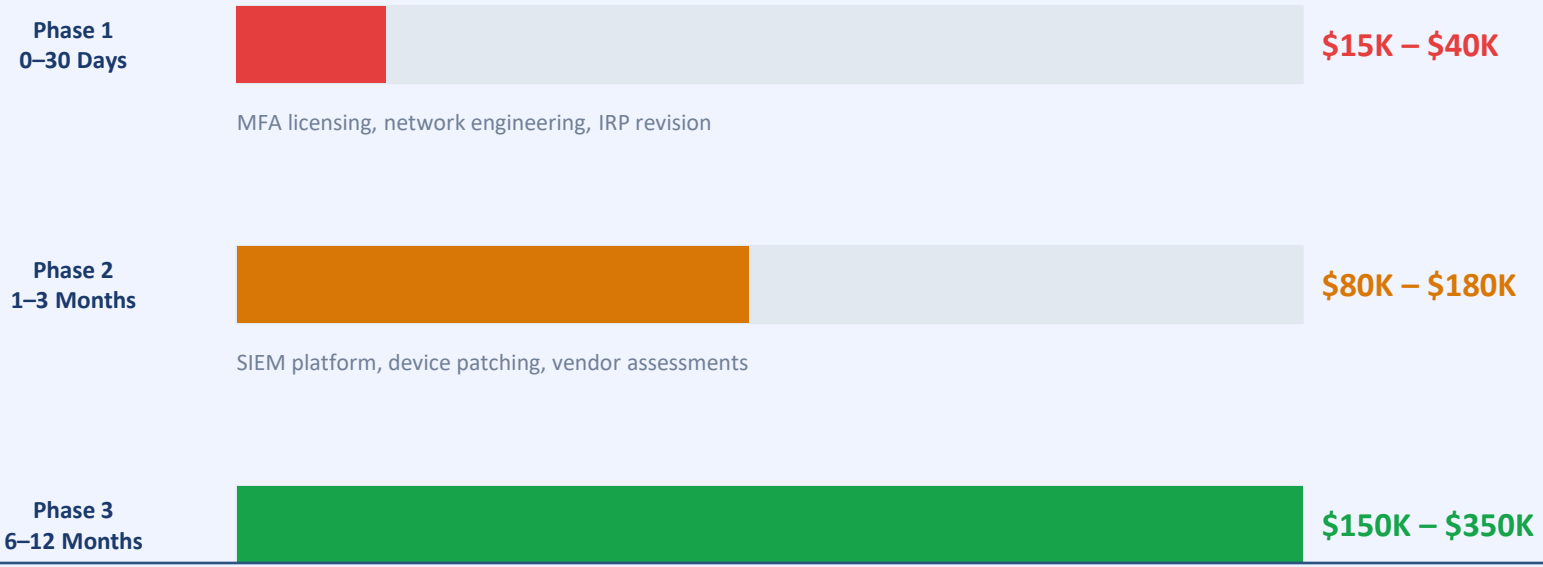
PHASE 3

6 – 12 Months

1. Enterprise GRC program
2. Role-based security awareness
3. 24/7 SOC monitoring capability
4. Full Business Continuity Plan
5. HITRUST CSF certification

BUDGET & PRIORITY CONSIDERATIONS

Investment Required vs. Cost of Inaction



MINIMUM VIABLE PROTECTION — If budget is constrained, prioritize: MFA Enforcement (P1-01) | Network Segmentation (P1-04) | Backup Encryption (P1-05)

COST OF INACTION: Ransomware recovery avg. $1.3M | HIPAA fine up to $1.9M/category | Cyber insurance denial if controls absent

CONCLUSION & NEXT STEPS

CURRENT POSTURE

HIGH RISK

Maturity: Level 1 — Ad Hoc

Score: 1.2 / 5.0

The ICU IT environment is operating at a risk level inconsistent with HIPAA obligations and patient safety expectations. Findings are serious — but remediable within 90 days with focused action.

01 IMMEDIATE (This Week)

- Assign executive sponsor for Phase 1
- Authorize emergency budget: MFA + segmentation
- Schedule CISO briefing on findings

02 30 DAYS

- MFA enforced — all EHR users
- ICU VLAN segmentation complete
- IRP revised and approved
- Backup encryption enabled

03 90 DAYS

- SIEM procurement underway
- Ransomware tabletop completed
- Vendor risk assessments initiated
- RTO/RPO defined and documented

Inaction is not a neutral position. Delay is a decision to accept consequences that may include regulatory enforcement, patient harm, and organizational disruption.